

OWASP Top 10 & API Security Comprehensive Audit Report

<https://app.thecoachgenie.in/>

Enterprise Security Architecture, Hardcoded Secrets & Access Control Evaluation

DAY
Tuesday

DATE
25 August 2026

TIME
12:45:49 PM IST

COMPLIANCE STATUS
10/10 OWASP Standards
Remediated

1. OWASP Top 10 Compliance Matrix (Post-Remediation)

Audit and remediation summary covering all 10 OWASP Top 10 vulnerability categories across CoachGenie Phase 1.

OWASP CATEGORY	SCOPE & TARGET	STATUS	ENFORCED REMEDIATION
A01: Broken Access Control	Students, Exams, Fees, Growth Cards	PATCHED	IDOR eliminated via tenant & user ownership validation.
A02: Cryptographic Failures	JWT Tokens & Secrets	PATCHED	All secrets moved to env vars; HSTS 2-year enforced.
A03: Injection	PostgreSQL 16 & SQLAlchemy	DEFENDED	100% parameterization via asyncpg (28/28 vectors defended).
A04: Insecure Design	Login & OTP Password Reset	PATCHED	Rate limiting (SlowAPI) + 3-attempt logout.
A05: Security Misconfig	Headers, CSP, Source Maps	PATCHED	CSP, HSTS, X-Frame-Options, source maps disabled.
A06: Outdated Components	Next.js 15 & Python Passlib	PATCHED	Next.js updated to patch CVEs; passlib removed.
A07: Auth & ID Failures	Session Invalidation on Logout	PATCHED	Refresh token revocation in database on logout.
A08: Software & Data Integrity	Supply Chain Verification	VERIFIED	0 typosquatted packages across all 6 manifests.
A09: Security Logging Failures	Exception Handlers	PATCHED	SQLAlchemy & Starlette exception masking active.
A10: SSRF	HTTP Clients & Webhooks	CLEAN	No user-controlled external URL fetching.